

Conformité réglementaire numérique : les questions à se poser

RGPD, NIS2, DORA, CSRD, AI Act : ouvrir le dialogue avec ses experts, pas s'y substituer

Avertissement

Ce document n'est pas un avis juridique et ne se substitue ni aux textes officiels ni à un conseil qualifié. Ce sont des questions de gouvernance, destinées à aider le dirigeant à ouvrir le dialogue avec ses responsables conformité, juridique et sécurité, et à situer le niveau de préparation de son organisation. Le périmètre exact des obligations dépend du secteur, de la taille et de la situation propre de chaque organisation.

RGPD

Protection des données personnelles (règlement 2016/679, applicable depuis 2018).

- ? Savons-nous quelles données personnelles nous traitons, où elles sont stockées et qui y accède ?
- ? Avons-nous une procédure éprouvée de notification d'une violation à l'autorité compétente dans le délai prévu ?
- ? Nos sous-traitants et fournisseurs offrent-ils des garanties documentées sur les données que nous leur confions ?

NIS2

Cybersécurité d'un large périmètre d'organisations (directive 2022/2555).

- ? Notre organisation entre-t-elle dans le périmètre de NIS2, et à quel titre ?
- ? Disposons-nous d'une analyse de notre niveau de conformité et d'un plan de remédiation chiffré ?
- ? Notre processus de notification des incidents significatifs aux autorités est-il défini et testé ?

DORA

Résilience opérationnelle numérique du secteur financier (règlement 2022/2554, appliqué depuis 2025).

- ? Sommes-nous concernés, comme acteur financier ou comme prestataire informatique critique d'un tel acteur ?
- ? Nos dépendances vis-à-vis de prestataires critiques, dont les grands fournisseurs cloud, sont-elles cartographiées ?
- ? Nos dispositifs de test de résilience opérationnelle sont-ils en place et documentés ?

CSRD

Reporting de durabilité des grandes entreprises et PME cotées (directive 2022/2464).

- ? La donnée extra-financière est-elle structurée dans le SI avec la même rigueur que la donnée comptable ?
- ? Avons-nous identifié l'impact de la CSRD sur la feuille de route SI Finance et Données ?
- ? Les responsabilités de production et de contrôle de ces données sont-elles attribuées ?

AI Act

Encadrement de l'intelligence artificielle par niveaux de risque (règlement 2024/1689, application progressive jusqu'en 2027).

? Savons-nous quels systèmes d'IA notre organisation utilise, à quelles fins, et dans quelle catégorie de risque ils s'inscrivent ?

? Avons-nous inventorié nos systèmes en cours de déploiement au regard de la classification de risque ?

? Pour les usages à risque élevé, savons-nous quelles exigences de documentation, de traçabilité et d'auditabilité s'appliqueraient ?

Référence dans le livre

Ces questions prolongent le chapitre 12 (cadre réglementaire de la cybersécurité) et le chapitre 13 (gouvernance de l'IA et AI Act), ainsi que la veille réglementaire du site. Page à préciser à la parution.

L'auteur s'exprime à titre personnel. © 2026 Mehdi Moudden.